A Standard For Investigative Playbooks

Matthew Gracie
Security Onion Solutions
BsidesROC 2026

Who Am I And What Am I Talking About?

What Is A Playbook?

"A cybersecurity playbook is a detailed framework that outlines organization-specific procedures for handling computer security events and incidents. It includes predefined courses of action that provide guidance on detecting, analyzing, and responding to potential cybersecurity threats."

Source: https://www.cynet.com/cybersecurity/why-cybersecurity-playbooks-are-critical-and-7-steps-to-create-your-own/

Playbook Principles

- In any given investigation, analysts ask investigative questions that they answer with data (evidence) to determine what happened and if malicious activity occurred.

Source: https://chrissanders.org/2025/06/human-centered-playbooks/

Playbook Principles

- In any given investigation, analysts ask investigative questions that they answer with data (evidence) to determine what happened and if malicious activity occurred.
- Analysts encounter common scenarios (cues) across diverse investigations based on the evidence they encounter and their forecasting of potentially related events.

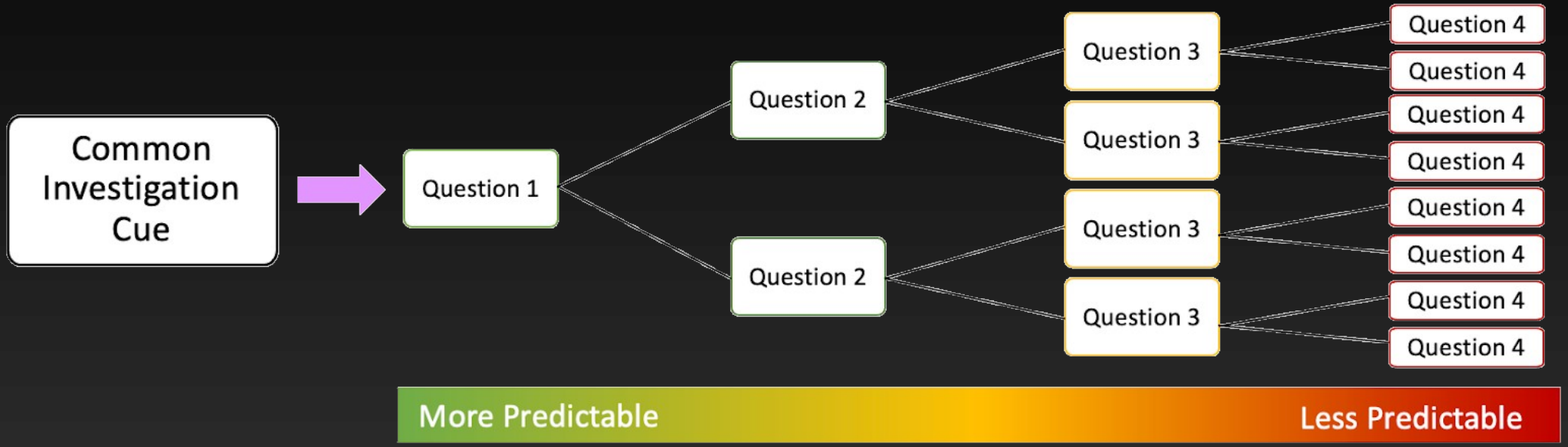
Source: https://chrissanders.org/2025/06/human-centered-playbooks/

Playbook Principles

- In any given investigation, analysts ask investigative questions that they answer with data (evidence) to determine what happened and if malicious activity occurred.
- Analysts encounter common scenarios (cues) across diverse investigations based on the evidence they encounter and their forecasting of potentially related events.
- Many of the initial investigative questions analysts will ask in response to these cues can be predicted.

Source: https://chrissanders.org/2025/06/human-centered-playbooks/

Playbook Principles



Source: https://chrissanders.org/2025/06/human-centered-playbooks/

Playbook Principles

- In any given investigation, analysts ask investigative questions that they answer with data (evidence) to determine what happened and if malicious activity occurred.
- Analysts encounter common scenarios (cues) across diverse investigations based on the evidence they encounter and their forecasting of potentially related events.
- Many of the initial investigative questions analysts will ask in response to these cues can be predicted.
- If you can predict the questions analysts will ask in an investigation, providing the analyst with a list of those questions when they encounter the cue has significant performance benefits.

Source: https://chrissanders.org/2025/06/human-centered-playbooks/

Example Scenario

You receive an alert in your SOC that an endpoint belonging to a user in Accounts Payable has launched a cURL process. What do you need to know?

Example Scenario

You receive an alert in your SOC that an endpoint belonging to a user in Accounts Payable has launched a cURL process. What do you need to know?

What is the parent process?

Does the user have admin rights?

Have they run cURL before?

What was the URL they were downloading from?

What was the file type they were retrieving?

Does Virustotal have a record of that hash?

How Are HCIP Playbooks Different?

"While some playbook standards exist, none are explicitly focused on interpretation by human analysts while also supporting integration into analyst-focused tools. That changes today with the release of the Human-Centered Investigation Playbook (HCIP) standard."

Source: https://chrissanders.org/2025/06/human-centered-playbooks/

HCIP Playbook Components

- Plain-language investigative questions.
- Context explaining why the question matters.
- Appropriate data and log sources for answering the question.
- Relative time ranges for pertinent evidence.
- Search queries tailored to the analyst’s tools.

HCIP Playbook Categories

- Artifact
- Attack Technique
- Attack Phase
- Malware Family
- Detection Signature

HCIP Playbook Categories

- Artifact
- Attack Technique
- Attack Phase
- Malware Family
- Detection Signature

Detection Engineering Scenario

A recent threat hunt identified data being exfiltrated from a workstation by a malicious process named wombat.exe. This executable had an original filename of dnsExfiltrator.exe and was apparently sourced from Github. It was written to disk by another executable called AVUpdate.exe, which was downloaded from a counterfeit web site that the user was sent to by a phishing email.

Wombat.exe was exfiltrating files using encoded DNS subdomains in very long TXT queries, all for the domain threescoops.online.

Detection Engineering Scenario

A recent threat hunt identified data being exfiltrated from a workstation by a malicious process named wombat.exe. This executable had an original filename of dnsExfiltrator.exe and was apparently sourced from Github. It was written to disk by another executable called AVUpdate.exe, which was downloaded from a counterfeit web site that the user was sent to by a phishing email.

Wombat.exe was exfiltrating files using encoded DNS subdomains in very long TXT queries, all for the domain threescoops.online.

Detection Engineering Scenario

If we find a client in our environment generating these long TXT requests, what do we want to know as investigators?

Detection Engineering Scenario

If we find a client in our environment generating these long TXT requests, what do we want to know as investigators?

Are there other DNS queries of type TXT from this endpoint?

What was the endpoint process that generated the DNS query traffic?

Are other endpoints in the environment requesting this domain?

What DNS server are these queries going to?

Demonstration

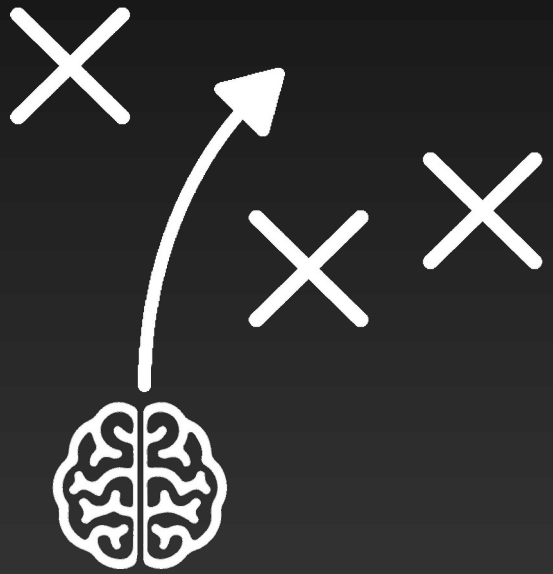
Playbooks As A Training Aid

- Using a Playbook during an investigation helps junior analysts learn by doing.
- Codifying knowledge into Playbooks helps scale senior analyst experience across multiple teams so others can benefit.
- The act of writing a new Playbook forces reflection and careful evaluation of assumptions and investigative techniques.

This standard isn't just a framework for guiding analysis, it's a tool for building better analysts.

Questions?

@infosecgoon

infosecgoon@roadflares.org

https://www.github.com/infosecgoon